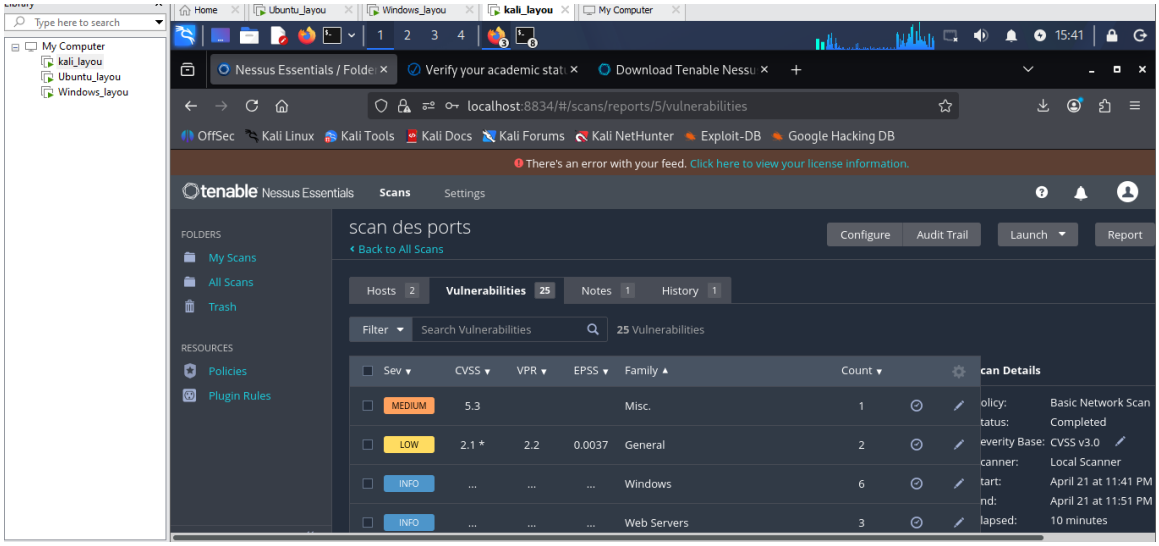
Compte rendu TP 2.2 : Analyse et correction des vulnérabilités (Linux + Windows)

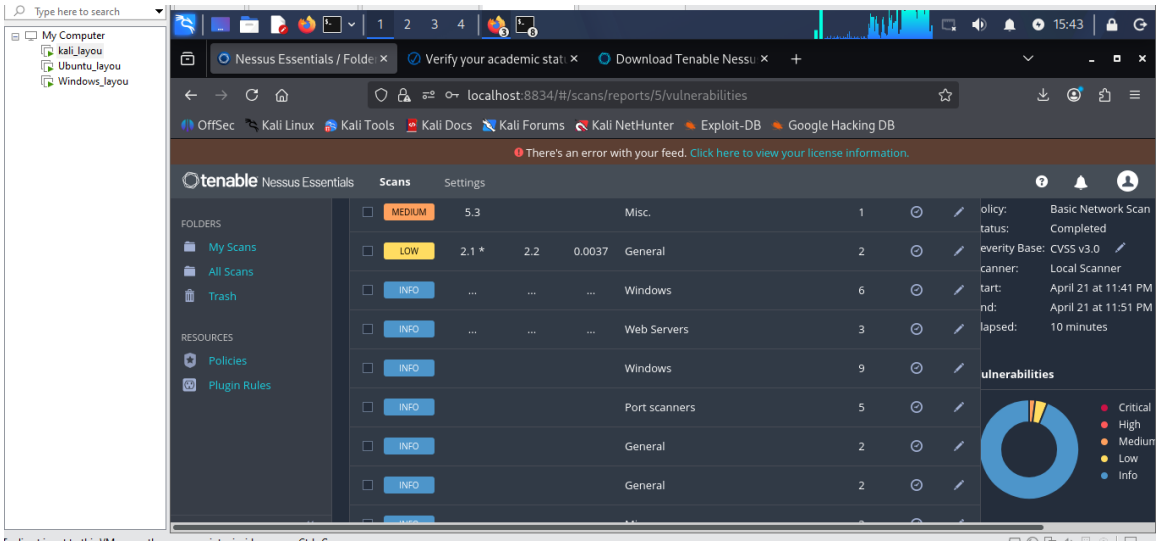
Objectif

Passer de « Je détecte » à « Je corrige » en analysant et corrigeant des vulnérabilités sur Linux et Windows.

Partie 1 : Analyse des vulnérabilités critiques

Choix de 2 vulnérabilités Linux et 2 vulnérabilités Windows.





Pare-feu désactivé 25 vulnérabilité scanées

Vulnérabilité Linux 1 192.168.56.10 (Sévérité : Haute,CVSS 7.5)

• **Nom :** Mauvaise configuration SSL/TLS

• **Problème :** Le service SSL/TLS utilise des paramètres de sécurité faibles.

• **Risque :** Les communications peuvent être interceptées par un attaquant.

• **Exploitation** : Un attaquant peut réaliser : des attaques Man-in-the-Middle , l'interception de données sensibles , l'exploitation de failles liées aux protocoles SSL/TLS .

Vulnérabilité Linux 2 (sévérité : critique, CVE-2024-1086 : noyau Linux)

- **Nom** : CVE 2024-1086-Use-after-free dans nf_tables
- **Probème:** Le noyau linux utilize une zone mémoire déjà libérée. Cela provoque un comportement imprévisible.
- **Risque** : Un attaquant local sans privilège peut devenir root (contrôle total). Des rançongiciels (RansomHub, Akira) l'exploitent activement
  L'attaquant injecte des règles spéciales dans le pare-feu du noyau
- **Exploitation :** Le noyau se trompe et exécute le code malveillant avec les droits maximum

Vulnérabilité Windows 192.168.56.20 – SMB (Sévérité : Moyenne, CVSS

• **Nom** : Mauvaise configuration du service SMB

• **Problème :**Le protocole SMB présente une configuration insuffisamment sécurisée (.

• **Risque** :Un attaquant peut accéder aux ressources partagées ou intercepter les communications réseau.

• **Exploitation :**Possibilité de capturer le trafic SMB , lancer des attaques réseau , exploiter des faiblesses connues du protocole .

Vulnérabilité Windows – ICMP (Sévérité : Faible, CVSS 2.1)

• **Nom :** Réponse ICMP active

• **Problème** :Le système répond aux requêtes ICMP (ping).

• **Risque :**Facilite la détection de la machine sur le réseau par un attaquant.

• **Exploitation :**Utilisé lors de la phase de reconnaissance pour : identifier les machines actives

Partie 2 : Correction Linux

Commande : sudo apt update && sudo apt upgrade -y

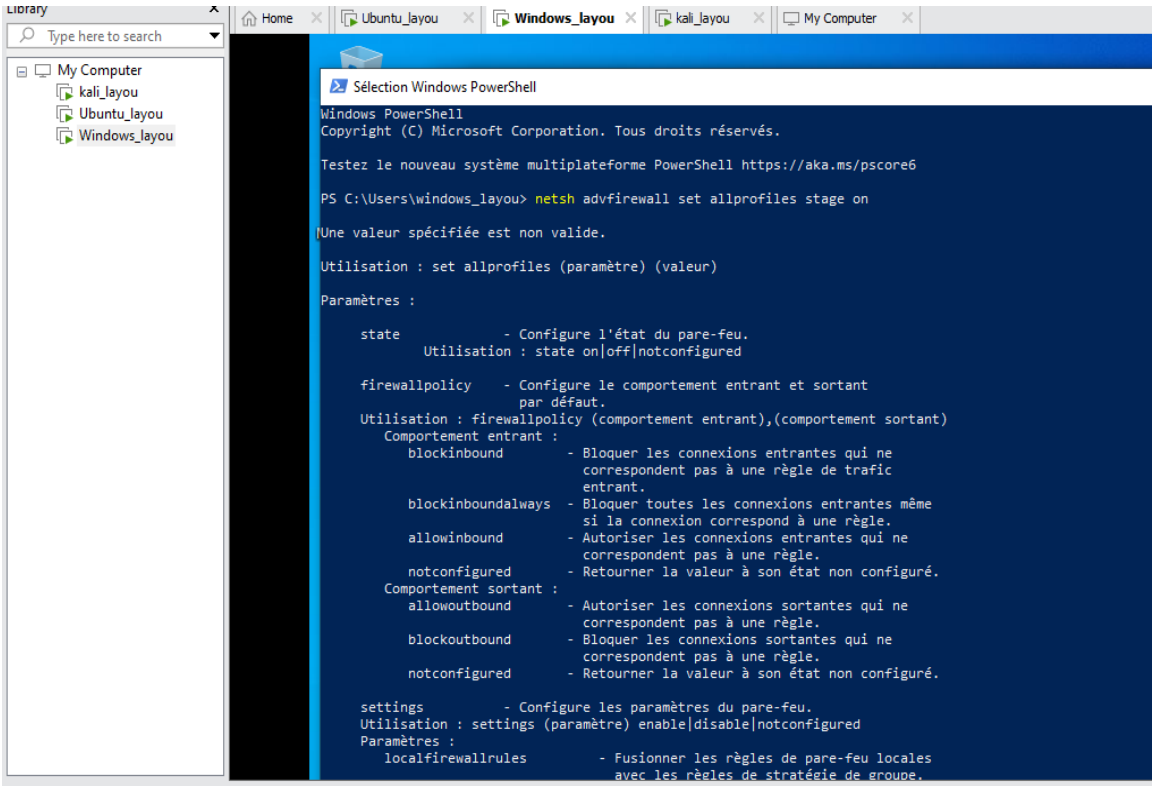
Déjà fait après installation des machines virtuelles

Commande : sudo ufw enable

```
revelk@revelk-VMware-Virtual-Platform:~$ sudo ufw enable
[sudo] Mot de passe de revelk :
Le pare-feu est actif et lancé au démarrage du système
revelk@revelk-VMware-Virtual-Platform:~$
```

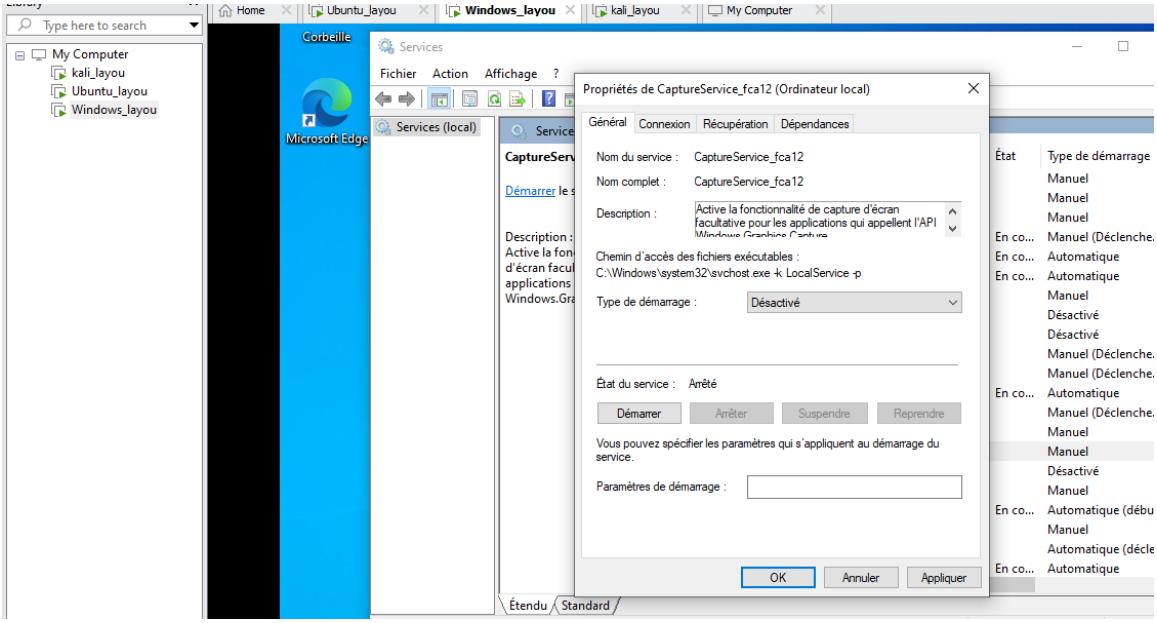
Partie 3 : Correction Windows

Commande: netsh advfirewall set allprofiles state on



Pour activation des pare-feu

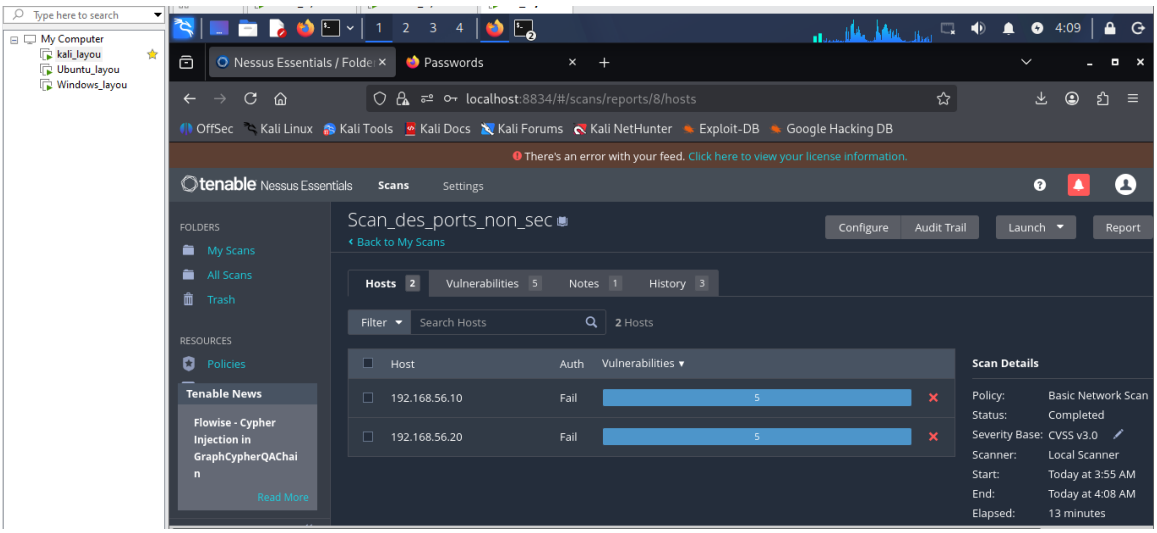
Commande : services.msc



Pour la désactivation des services inutiles

Partie 4 : Re-scan Nessus

Relancer le scan.



Comparaison avant/après correction.
Après avoir appliqué les corrections, nous avons lancé un nouveau scan au nom Scan-des-ports- sec nous avons obtenu un résultat différent du à la sécurité faite en activant les pare-feu dans nos machines cibles

Les résultats que nous avons obtenus sont :

- Avant correction : 25 vulnérabilités détectées
- Après correction, nous observons une réduction significative du nombre de vulnérabilités dont 5.
- Résultats attendus

- Moins de vulnérabilités
- Amélioration du score

Conclusion

Ce TP a permis de comprendre que :

• La détection des vulnérabilités est une première étape essentielle

• La correction est indispensable pour sécuriser un système

• Les outils comme Nessus permettent une analyse professionnelle des risques